

Manual 13 - Implementação Controlada SOX ITGC / ICFR

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: bd95c57ec7c4f55f6c2c8720afa1ad9df4c16679 | Idioma: pt-BR | limites de autoridade SOX/SEC/PCAOB mantidos.

Limite jurídico e de auditoria: Este manual oferece orientação prática para controles tecnológicos de ICFR. Não fornece aconselhamento jurídico específico, não determina materialidade, status do emissor, isenções, classificação de deficiências, escopo do auditor nem garante conformidade SOX. Fontes vigentes e julgamento humano competente permanecem controlantes.

Caminhos de implementação

Manual 13 — Caminhos de implementação SOX ITGC / ICFR

Rascunho localizado assistido por máquina. A fonte inglesa controlada prevalece até revisão semântica humana competente.

Caminho Essencial

Defina escopo tecnológico de ICFR, sistemas e processos significativos, responsáveis, ITGC básicos de acesso/mudanças/operações, evidência, testes da administração e remediação.

Manual 03 memory graphic 1

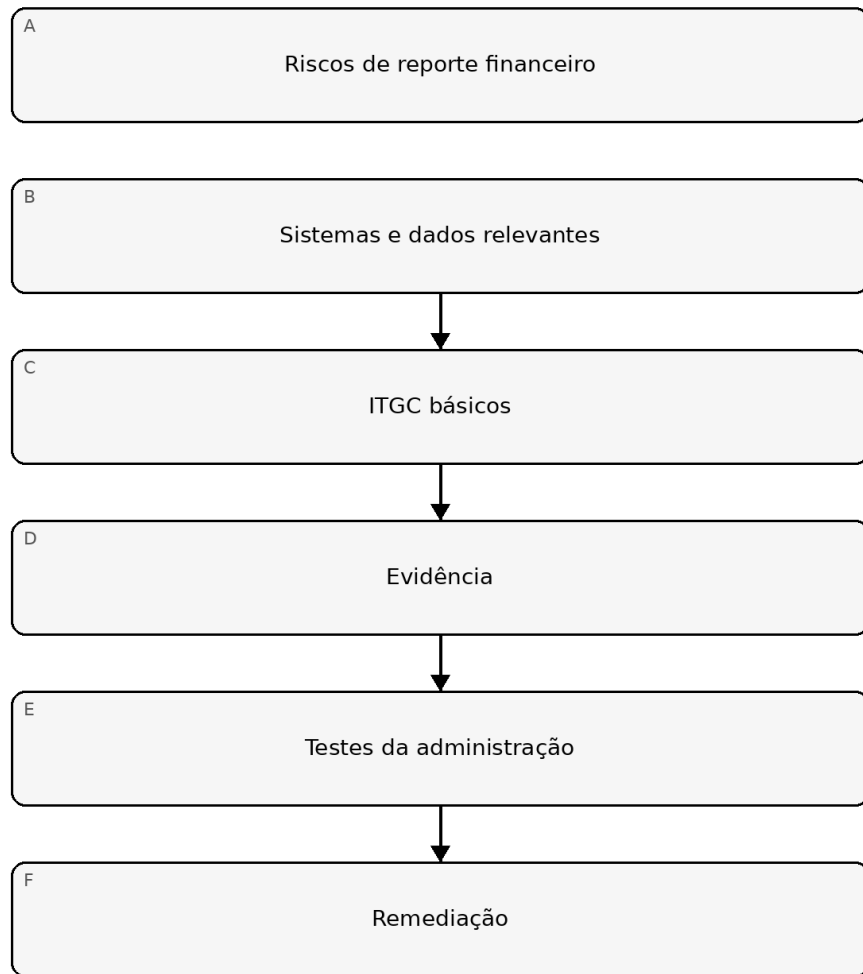


Figure 1. Implementation memory graphic

Explicação acessível: Comece pelos riscos financeiros, identifique a tecnologia de suporte, opere ITGC, retenha evidência, teste controles e remedie falhas.

Caminho Estruturado

Adicione ligação a asserções, controles de completude de população, procedimentos padronizados, validação de IPE, governança de organizações de serviço e suporte formal às certificações.

Manual 03 memory graphic 2

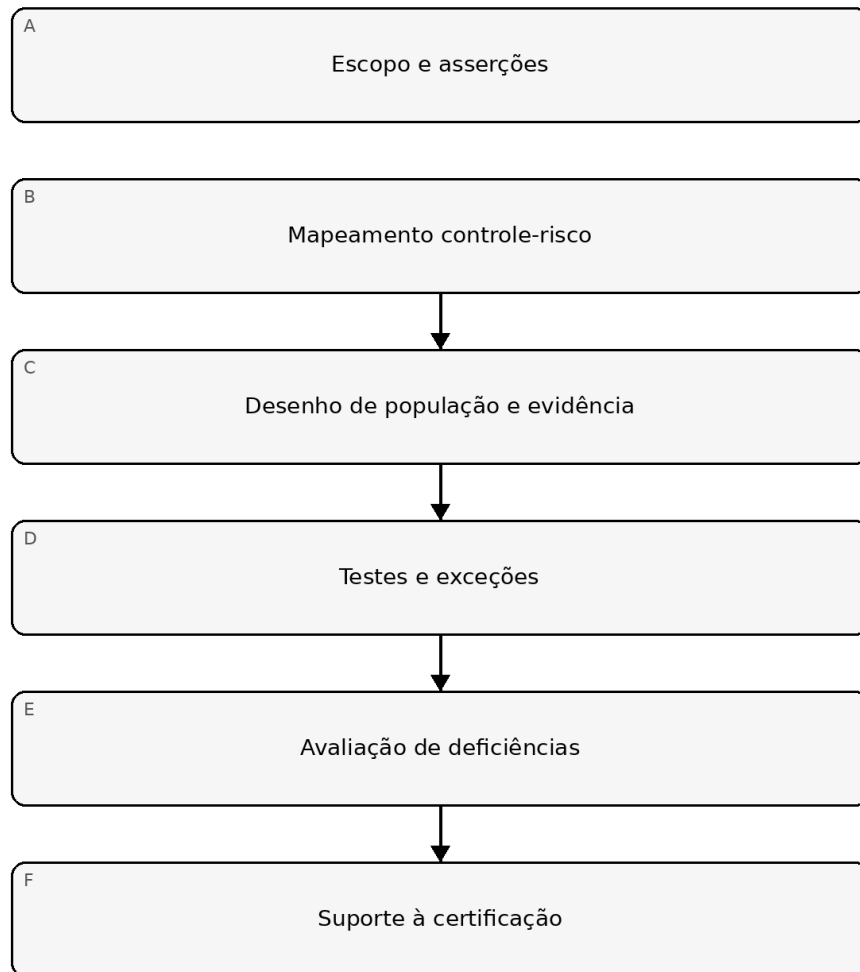


Figure 2. Implementation memory graphic

Explicação acessível: O caminho estruturado conecta escopo e asserções a controles, valida populações/evidência, administra exceções e alimenta a certificação.

Caminho Aprimorado

Incorpore monitoramento contínuo, proveniência automatizada de evidência, analítica de configuração/identidade, detecção de mudanças, integração cloud/SaaS e governança de IA/automação financeiramente relevante.

Manual 03 memory graphic 3

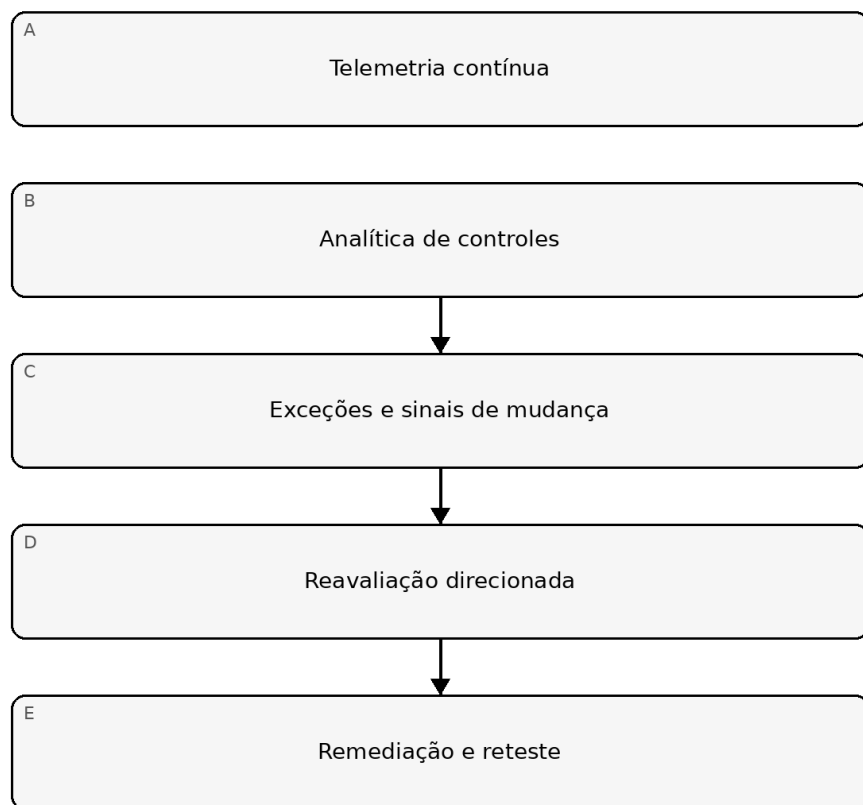


Figure 3. Implementation memory graphic

Explicação acessível: O modelo aprimorado usa sinais contínuos para detectar exceções, acionar reavaliação, remediar e retestar.

Manual controlado de 32 capítulos

Capítulo 1 — Finalidade e limite operacional

Este manual converte obrigações tecnológicas relacionadas a SOX/ICFR em um modelo prático de governança, controle e evidência. Distingue lei e regras da SEC, requisitos de auditoria do PCAOB, orientação regulatória e estruturas opcionais. Não substitui aconselhamento jurídico nem julgamento profissional sobre materialidade, aplicabilidade ou escopo de auditoria.

Capítulo 2 — Contexto das Seções 302 e 404

As certificações executivas da Seção 302 e a avaliação de ICFR da Seção 404 exigem responsabilidades relacionadas, porém distintas. Deve existir um mapa de responsabilidades conectando certificação, controles, sistemas, relatórios e escalonamento.

Capítulo 3 — Administração versus auditor externo

A administração projeta, opera, avalia e documenta ICFR. O auditor externo realiza avaliação independente quando aplicável. Testes da administração devem permanecer separados dos procedimentos do auditor.

Capítulo 4 — Escopo e aplicabilidade

Defina entidade, contas e divulgações relevantes, processos significativos, aplicações financeiras, interfaces, infraestrutura, prestadores, relatórios e planilhas. Documente por que cada componente está dentro ou fora do escopo.

Capítulo 5 — Risco de reporte financeiro e asserções

Vincule riscos de processo a asserções, contas/divulgações, controles automatizados, relatórios, interfaces e dependências de TI. Cada ITGC deve explicar como sua falha pode afetar um objetivo de reporte financeiro.

Capítulo 6 — Governança e responsabilização

Atribua responsáveis executivos, donos de processo e controle, donos de sistemas, custodiante de evidência, testadores, revisores e responsáveis por remediação. Defina escalonamento para falhas, exceções recorrentes e remediações vencidas.

Capítulo 7 — Controles tecnológicos em nível de entidade

Controles em nível de entidade incluem governança de acesso, mudanças, operações, segurança, riscos, monitoramento e supervisão de sistemas financeiros. Políticas gerais isoladas não comprovam eficácia operacional.

Capítulo 8 — Domínios ITGC e relevância para ICFR

Organize ITGC em acesso a programas e dados, mudanças, desenvolvimento/aquisição e operações, complementados por interfaces, IPE/relatórios e dependências modernas quando necessário. Evite ampliar SOX para controles de cibersegurança sem vínculo financeiro.

Capítulo 9 — Governança de acesso lógico

Defina admissão, movimentação, desligamento, acesso privilegiado, contas de serviço, acesso emergencial e revisões periódicas para sistemas financeiramente relevantes. A evidência deve mostrar solicitação, aprovação, implementação, remoção tempestiva, revisão, exceções e remediação.

Capítulo 10 — Segregação de funções e acesso privilegiado

Identifique combinações incompatíveis que permitam transações, mudanças, lançamentos, alterações em dados mestres ou ocultação de erros. Quando a segregação técnica não for viável, documente e teste controles compensatórios.

Capítulo 11 — Gestão de mudanças

Exija solicitação autorizada, avaliação de impacto, testes, aprovação, migração controlada, restrição de acesso à produção e evidência posterior. Diferencie mudanças rotineiras, padrão, emergenciais, configuração, código, infraestrutura como código e mudanças SaaS.

Capítulo 12 — Desenvolvimento, aquisição e implementação

Para novos sistemas ou implementações relevantes, documente requisitos, desenho de controles, conversão de dados, validação de interfaces, UAT, acesso, segregação, corte, rollback e monitoramento pós-implantação.

Capítulo 13 — Operações de TI

Controle jobs, processamento em lote, interfaces, backups, recuperação, monitoramento, falhas, reprocessamentos, incidentes e mudanças operacionais. A evidência deve demonstrar detecção e resolução de exceções.

Capítulo 14 — Interfaces e transferências de dados

Mantenha inventário de interfaces financeiramente significativas e controles de completude, exatidão, autorização, reconciliação, tratamento de erros, rejeições e duplicidades.

Capítulo 15 — Relatórios e informações produzidas pela entidade (IPE)

Valide fonte de dados, parâmetros, lógica, acesso, histórico de mudanças e completude/exatidão de relatórios, consultas, extrações, painéis e cálculos usados em controles ou reporte financeiro.

Capítulo 16 — Planilhas e computação de usuário final

Classifique planilhas e ferramentas EUC por risco. Aplique propriedade, acesso, versionamento/mudanças, proteção ou revisão de fórmulas, validação de entradas, reconciliação, backup e revisão independente.

Capítulo 17 — Eficácia do desenho

Avalie se cada controle, executado conforme projetado, preveniria ou detectaria oportunamente o risco de reporte financeiro. Documente objetivo, gatilho, população, executor, precisão, evidência, dependências e escalonamento.

Capítulo 18 — Eficácia operacional

Determine se o controle operou durante o período, por pessoal adequado, com evidência consistente e acompanhamento tempestivo. Defina população e período antes de selecionar amostras.

Capítulo 19 — Desenho e retenção de evidência

Especifique evidência esperada, sistema de origem, responsável, local de retenção, período, vínculo com a população e atributos de revisão. Prefira evidência gerada naturalmente pelo controle.

Capítulo 20 — Completude da população e preparação para amostragem

Documente como as populações são geradas, por que são completas, filtros, duplicidades, exclusões e registros ausentes. Tamanho de amostra requer julgamento profissional e não é universalmente prescrito.

Capítulo 21 — Organizações de serviço e terceiros

Mapeie serviços terceirizados que afetam ICFR, controles complementares da entidade usuária, subservice organizations, relatórios de controle, contratos, incidentes, mudanças e lacunas. Um relatório SOC não comprova automaticamente cobertura total.

Capítulo 22 — Nuvem e SaaS

Documente responsabilidades compartilhadas para serviços financeiramente relevantes: configuração, acesso privilegiado, federação de identidade, mudanças, logs, backup, interfaces e evidência disponível.

Capítulo 23 — IA e automação em processos financeiros

Quando IA, RPA ou automação influenciar cálculos, classificações, reconciliações, aprovações, relatórios ou evidência, documente finalidade, entradas, saídas, supervisão humana, mudanças, acesso, validação, monitoramento e contingência.

Capítulo 24 — Identificação e escalonamento de deficiências

Registre falhas de controle, lacunas de desenho, falhas de evidência, exceções recorrentes e dependências afetadas. Separe o achado factual da classificação jurídica ou de auditoria como deficiência significativa ou fraqueza material.

Capítulo 25 — Planejamento de remediação

Para cada achado identifique causa raiz, objetivo afetado, sistemas/processos, dono do risco, ação corretiva, data-alvo, controle interino, evidência e critérios de reteste.

Capítulo 26 — Reteste e encerramento

O reteste deve confirmar desenho e operação da remediação. Preserve achado original, evidência de correção, evidência de reteste, conclusão do revisor e aprovação de encerramento.

Capítulo 27 — Suporte às certificações da administração

Integre status de controles, mudanças significativas, deficiências, remediações, entradas do processo de divulgação e assuntos em aberto. Representações tecnológicas devem ser rastreáveis à evidência do período.

Capítulo 28 — Interação com auditor externo

Mantenha processo controlado de entrega de evidência com acompanhamento de solicitações, responsáveis, prazos, versões e escalonamento. Não altere evidência subjacente apenas para atender a uma solicitação.

Capítulo 29 — Monitoramento contínuo e reavaliação

Use métricas, recertificação de acessos, dados de incidentes, jobs com falha, exceções e aging de remediações para detectar deterioração. Monitoramento não substitui operação nem testes independentes.

Capítulo 30 — Caminhos Essencial, Estruturado e Aprimorado

Essencial: escopo defensável, ITGC básicos, responsáveis, evidência e gestão de deficiências. Estruturado: ligação risco-asserção, populações, testes padronizados, terceiros e remediação integrada. Aprimorado: monitoramento contínuo, proveniência automatizada de evidência, analítica de configuração e reavaliação acionada por mudanças.

Capítulo 31 — Falhas comuns e cenários

Falhas comuns incluem excesso de escopo de cibersegurança, capturas sem evidência populacional, confiança automática em relatórios SOC, validação fraca de IPE, acesso privilegiado não resolvido, mudanças emergenciais sem revisão e encerramento de remediação sem reteste.

Capítulo 32 — Lista final de operação e publicação

Verifique status atual de fontes SOX/SEC/PCAOB, escopo, responsáveis, rastreabilidade, evidência, fidelidade de localização, acessibilidade, proveniência e histórico de mudanças. Para publicação, vincule hashes exatos, QA, revisões, manifesto, segurança de workflow e reconciliação de registro/catálogo.

Apêndice de evidência e testes para praticantes

Apêndice de evidência e testes para praticantes — Manual 13

A. Planilha controle-risco

Para cada controle tecnológico financeiramente relevante registre risco de reporte financeiro, processo/conta/divulgação, asserção ou objetivo afetado, sistema ou dado dependente, dono do controle, executor, frequência, fonte de evidência, local de retenção, dependências, caminho de exceção e gatilho de reavaliação. Um revisor deve conseguir entender por que o controle está no escopo de ICFR e como uma falha pode afetar o reporte financeiro.

B. Padrão de evidência de acesso

Para acessos de usuário preserve solicitação, aprovação, função ou privilégio concedido, data de implementação, administrador, registro do sistema, revisão periódica e remediação. Para acesso privilegiado inclua justificativa, limites, monitoramento e recertificação. Para desligamentos demonstre a população fonte e a tempestividade da remoção; capturas isoladas não comprovam completude.

C. Padrão de gestão de mudanças

Para mudanças financeiramente relevantes preserve solicitação aprovada, avaliação de impacto, descrição/requisitos, testes, segregação, aprovação de migração, registro de implantação e validação posterior. Mudanças emergenciais exigem justificativa documentada e revisão retrospectiva. Em SaaS e low-code, mudanças de configuração, fluxos, fórmulas, permissões e integrações podem ser tão relevantes quanto alterações de código.

D. Padrão de operações de TI

Para processamentos agendados identifique população esperada, monitoramento, critérios de falha, notificação, autoridade para reinício/reprocessamento, reconciliações e evidência de resolução. Um status de scheduler bem-sucedido pode ser insuficiente quando a completude financeira depende de contagens, totais de controle ou reconciliações posteriores.

E. Interfaces e reconciliações

Documente origem/destino, frequência, população, mecanismo de transferência, controles automatizados, tratamento de rejeições, duplicidades, reconciliação, limites e responsáveis. Quando a reconciliação for manual, defina a precisão do revisor e o escalonamento; se automatizada, documente configuração/código, entradas, tratamento de erros e monitoramento.

F. IPE e relatórios

Quando um controle depende de relatório, consulta, extração ou painel, documente nome, sistema, dono, parâmetros, período, filtros, fonte de dados, lógica e acesso. Para consultas ad hoc preserve script/consulta exata. Para planilhas registre fontes, fórmulas/macros, versão, acesso, revisão e reconciliação. Uma captura de tela não substitui evidência reproduzível da população.

G. Organizações de serviço

Para cada prestador que afete ICFR documente serviço, processos/sistemas, relatório ou evidência revisada, período, controles complementares da entidade usuária, subservice organizations, exceções, período-ponte, incidentes e conclusão da administração. Receber um relatório SOC não significa confiar automaticamente em todos os controles relevantes.

H. Mínimos do papel de trabalho de testes

Inclua ID do controle, objetivo, risco, descrição, dono, frequência, fonte da população, período, método, fundamento da amostra quando aplicável, itens testados, evidência, exceções, conclusão, revisor, data e acompanhamento. Separe desenho de eficácia operacional e assegure que outro revisor competente possa reproduzir a lógica da conclusão.

I. Deficiência e remediação

Registre condição factual, objetivo afetado, processo/sistema, duração, população potencial, controles compensatórios, causa raiz, contenção, ação corretiva, dono, prazo, evidência de encerramento e plano de reteste. Mantenha os fatos separados da classificação final como deficiência significativa ou fraqueza material.

J. Reavaliação por mudanças

Reavalie escopo e desenho após implementação relevante, migração ERP, aquisição, nuvem, mudança de identidade, terceirização, redesenho financeiro, nova interface, incidente material, exceção recorrente ou introdução de IA/automação financeiramente relevante. Registre evento, escopo afetado, riscos, controles alterados, evidência e testes requeridos.

K. Cenário — acesso privilegiado

Um administrador financeiro mantém privilégios após uma janela emergencial. Identifique sistemas/capacidades afetadas, revise atividade, corrija o acesso, avalie monitoramento, registre a exceção e determine se os testes precisam ser ampliados. A classificação final exige julgamento competente.

L. Cenário — parâmetro incorreto de relatório

Uma reconciliação mensal usa filtro de data incorreto por dois períodos. Reproduza populações corretas, avalie erros potencialmente não detectados, identifique controles alternativos, corrija procedimento/configuração, reteste e avalie a deficiência com critérios vigentes e fatos específicos.

M. Cenário — mudança de configuração SaaS

Um prestador altera um fluxo financeiro configurável. Determine impacto em aprovações, acesso, cálculos, interfaces ou evidência; obtenha informações disponíveis, compare configuração, teste o fluxo, atualize documentação e reavalie a dependência do prestador.

N. Cenário — processo financeiro assistido por IA

Uma ferramenta de IA propõe classificações contábeis. Controle uso aprovado, proveniência de entradas, revisão de saídas, mudanças, acesso, fallback, monitoramento, exceções e evidência. Pontuações de confiança do modelo não comprovam exatidão financeira; defina como a revisão humana valida resultados e escala anomalias.

O. Lista de evidência de publicação

O pacote final deve vincular identidade exata da fonte controlada, verificação de fontes autoritativas, fontes trilingues, DOCX/PDF, QA de páginas, revisão de acessibilidade/visual, hashes, manifesto, segurança de workflows, reconciliação de mudanças e decisões de revisão aplicáveis ligadas ao candidato exato. A autorização final permanente já está estabelecida separadamente.